

Nätverk och säkerhet

Ett segmenterat virtuellt nätverk för Novatrix kundtjänst

Virtuellt nätverk	Vnet-Novatrix	10.20.0.0/16
Publikt subnät	snet-public	10.20.1.0/24
Privat subnät	snet-private	10.20.2.0/24

Adrian Forgo Ahlborg

Novatrix AB · Sweden Central · RG-novatrix

<https://github.com/adrianahlborg404-png/Azure-novatrix-mov25>

1 Vad jag har gjort

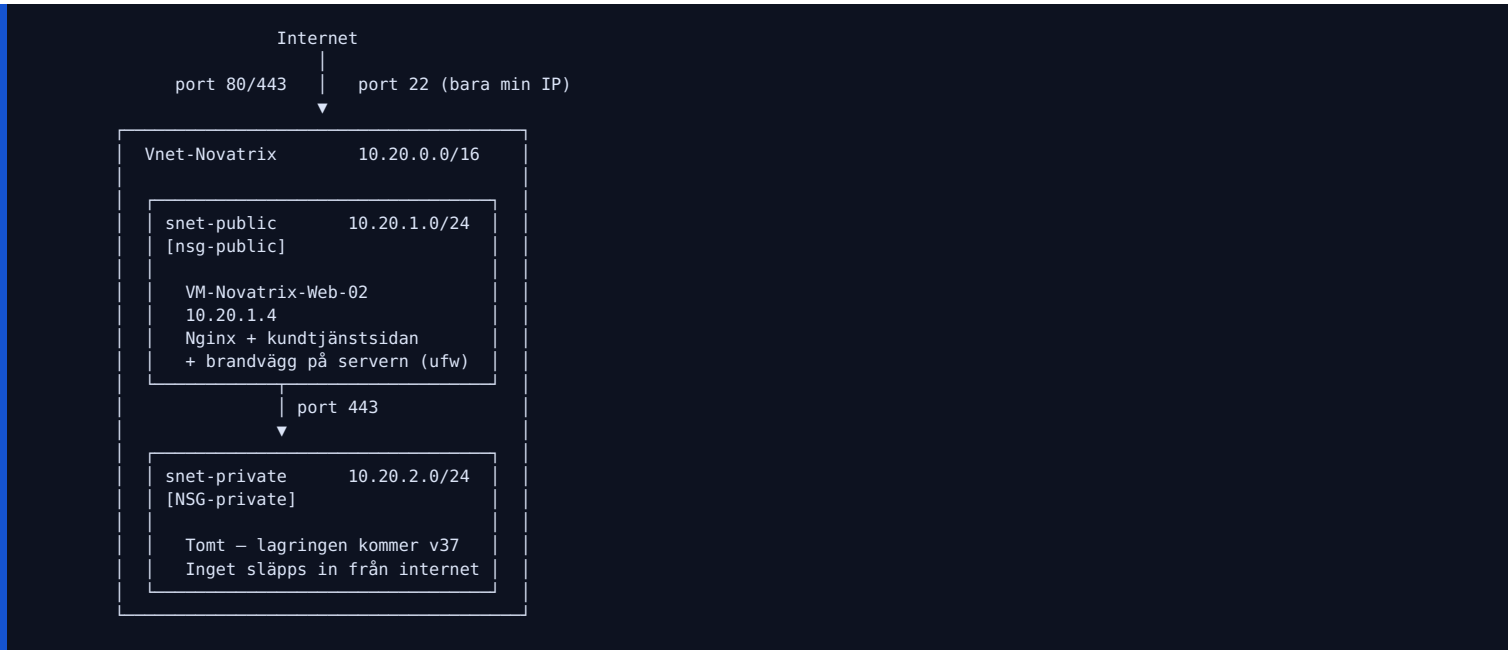
Jag har byggt ett eget virtuellt nätverk runt Novatrix kundtjänst och delat upp det i en publik och en privat del. Webbservern med ärendeformuläret ligger i den publika delen, och den privata delen står tom och redo för lagringen som kommer i v37. Trafiken styrs av brandväggsregler som bara släpper igenom det som behövs.

Delmoment	Vad jag gjorde	Bevis
Nätverk	<code>Vnet-Novatrix</code> med två subnät	Skärmbild 01
Brandväggar	Två NSG:er, en per subnät	Skärmbild 02, 03
Koppling	NSG:erna kopplade till varsitt subnät	Skärmbild 04, 05
Placering	Servern byggd direkt i <code>snet-public</code>	Skärmbild 06
Extra lager	Brandvägg på själva servern	Skärmbild 07
Verifiering	Testat vad som släpps igenom och vad som stoppas	Skärmbild 08-13

2 Min miljö

Objekt	Värde
Resursgrupp	<code>RG-novatrix</code>
Virtuellt nätverk	<code>Vnet-Novatrix</code> (<code>10.20.0.0/16</code>)
Publikt subnät	<code>snet-public</code> (<code>10.20.1.0/24</code>)
Privat subnät	<code>snet-private</code> (<code>10.20.2.0/24</code>)
Virtuell maskin	<code>VM-Novatrix-Web-02-vecka-36-ny</code>
Publik IP	<code>74.241.168.58</code>
Privat IP	<code>10.20.1.4</code>
Region	Sweden Central

3 Nätverksdesign



Uppdelningen bygger på en enda fråga: **behöver den här saken nås från internet?** Formuläret måste besökare komma åt, alltså ligger det publikt. Lagringen ska ingen utomstående komma åt, alltså ligger den privat. Gränsen mellan subnäten är det som gör skillnaden möjlig att upprätthålla med regler.

Jag valde `10.20.0.0/16` som adressutrymme och gav varje subnät ett eget `/24`.
Det räcker med god marginal och lämnar plats för fler subnät längre fram.

Start > Vnet-Novatrix-1788774173982 | Översikt > Vnet-Novatrix

Vnet-Novatrix | Undernät

Virtuellt nätverk

Sök

Översikt

Aktivitetslogg

Åtkomstkontroll (IAM)

Taggar

Diagnostisera och lösa problem

Resursvisualisera

Inställningar

Adressutrymme

Anslutna enheter

Undernät

Bastion

DDoS-skydd

Brandvägg

Microsoft Defender för molnet

Nätverkshanterare

DNS

Peering-sessioner

Tjänstens slutpunkter

Lägg till eller ta bort favoriter genom att trycka på

+ Undernät

Uppdatera

Hantera användare

Ta bort

Exportera till CSV

Sök efter undernät

	Namn ↑	IPv4	IPv6	Tillgängliga IP...	Delegerat till	Säkerhetsgrupp	Routningstabell		
☐	snet-public	10.20.1.0/24	-	251	-	-	-		
☐	snet-private	10.20.2.0/24	-	251	-	-	-		

Visar 2 undernät

Ge feedback

Skärmbild 01. Undernäten snet-public och snet-private i Vnet-Novatrix.

4 Brandväggsreglerna och varför de ser ut så

nsg-public

Prioritet	Namn	Släpper in	Varför
100	Allow-HTTP	port 80 från internet	Besökare måste nå formuläret
110	Allow-HTTPS	port 443 från internet	Förberett för certifikat
120	Allow-SSH-Admin	port 22, bara <code>31.208.x.x/32</code>	Jag behöver kunna administrera servern
65500	DenyAllInBound	inget	Azures inbyggda sistaregel

Regel 120 är den viktigaste. Standard när man skapar en VM i Azure är att SSH öppnas mot hela internet, och då kan vem som helst i världen sitta och gissa sig in. Genom att sätta källan till min egen adress är porten stängd för alla andra.

Jag behövde ingen egen regel som stänger resten. Azure har en inbyggd sistaregel som nekar allt ingen tidigare regel har tillåtit. Regler läses uppifrån och ner, och den första som matchar avgör.


```
snet-private.
```

Skärmbild 04. nsg-public kopplad till undernätet snet-public.

Skärmbild 05. NSG-private kopplad till undernätet snet-private.

6 Var servern hamnade

jag nätverket först och servern sist. Då hamnade den rätt direkt.

VM-Novatrix-Web-02-vecka-36-ny | Nätverksinställningar

☆ ...

Visa en lista över alla mina nätverksgränssnitt för (0).

Hur gör jag den här virtuella datorn säker? +1

Virtuell dator

Ök

Essentials

Översikt

Aktivitetsslogg

Ätkomstk kontroll (IAM)

Aggar

Diagnostisera och lösa problem

Övervaka

Resursvisualisering

Inslut

Nätverk

Nätverksinställningar

Belastningsutjämning

Programsäkerhetsgrup...

Nätverkshanterare

Ställningar

Illgänglighet och skala

Säkerhet

Säkerhetskopiering och
åverberedskap

tgärder

Öll eller ta bort favoriter genom att trycka på
Ctrl+Shift+F

Nätverksgränssnitt : vm-novatrix-web-02-vecka-36-ny398

Virtuellt nätverk / under... : Vnet-Novatrix / snet-public

Offentlig IP-adress : 74.241.168.58

Privat IP-adress : 10.20.1.4

Administratörssäkerhetsr... : 0 (Konfigurera)

Lastbalanserare : 0 (Konfigurera)

Programsäkerhetsgrupper : 0 (Konfigurera)

Nätverkssäkerhetsgrupp : -

Accelererat nätverk : Inaktiverat

Gällande säkerhetsregler : 0

✓ Nätverkssäkerhetsgrupp nsg-public (kopplat till undernät: snet-public)

Påverkar 1 undernät, 0 nätverksgränssnitt

+ Skapa portregel ▾

Sök regler

Källa == alla

Mål == alla

Protokoll == alla

Åtgärd == alla

Port == alla

Prioritet ↑	Namn	Port	Protokoll	Källa	Mål	Åtgärd
Regler för portar för inkommande trafik (6)						
100	Allow-HTTP	80	TCP	Valfritt	Valfritt	Allow
110	Allow-HTTPS	443	TCP	Valfritt	Valfritt	Allow
120	Allow-SSH-Admin	22	TCP	31.208.29.95/32	Valfritt	Allow
65000	AllowVnetInBound ⓘ	Valfritt	Valfritt	VirtualNetwork	VirtualNetwork	Allow
65001	AllowAzureLoadBalancerInBound ⓘ	Valfritt	Valfritt	AzureLoadBalancer	Valfritt	Allow
65500	DenyAllInBound ⓘ	Valfritt	Valfritt	Valfritt	Valfritt	Deny

Skärmbild 06. Serverns nätverksinställningar med subnät, privat adress och kopplad NSG.

Bilden visar tre saker jag ville kunna bevisa:

Servern ligger i `Vnet-Novatrix / snet-public`, och dess privata adress `10.20.1.4` ligger inom det publika subnätets intervall.

Fältet **Nätverkssäkerhetsgrupp** på nätverkskortet står tomt, alltså finns ingen extra brandvägg där. Det var ett medvetet val — hade nätverkskortet haft en egen NSG skulle två uppsättningar regler behöva släppa igenom samma trafik, och det blir svårt att felsöka när något blockeras.

Rutan under visar att `nsg-public` är kopplad via undernätet och påverkar 1 undernät och 0 nätverksgränssnitt. Ett enda lager på nätverkssidan, tydligt och lätt att följa.

7 Defense in depth - flera lager

Poängen är att ingen enskild inställning ska vara det enda som står mellan en angripare och lösningen. Om ett lager fallerar finns nästa kvar.

Lager	Vad det gör
Nätverksdelning	Publikt och privat subnät är åtskilda
NSG på publikt subnät	Bara port 80, 443 och SSH från min adress
NSG på privat subnät	Ingenting från internet, bara från webbservern
Brandvägg på servern	ufw stoppar allt utom port 22 och 80
SSH-nycklar	Ingen lösenordsinloggning, alltså inget att gissa
RBAC från v35	Även den som får åtkomst kan bara göra det rollen tillåter
Hanterad identitet	Inga lösenord i koden att stjäla

De tre nedersta byggde jag inte den här veckan, men de hör till samma försvar. Nätverket är ett lager, inte hela skyddet.

```
azureuser@VM-Novatrix-Web-02-veck-36-ny:~$ sudo ufw allow 22
/tcp
sudo ufw allow 80/tcp
sudo ufw --force enable
sudo ufw status verbose
Rules updated
Rules updated (v6)
Rules updated
Rules updated (v6)
Firewall is active and enabled on system startup
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
22/tcp ALLOW IN Anywhere
80/tcp ALLOW IN Anywhere
22/tcp (v6) ALLOW IN Anywhere (v6)
80/tcp (v6) ALLOW IN Anywhere (v6)

azureuser@VM-Novatrix-Web-02-veck-36-ny:~$
```

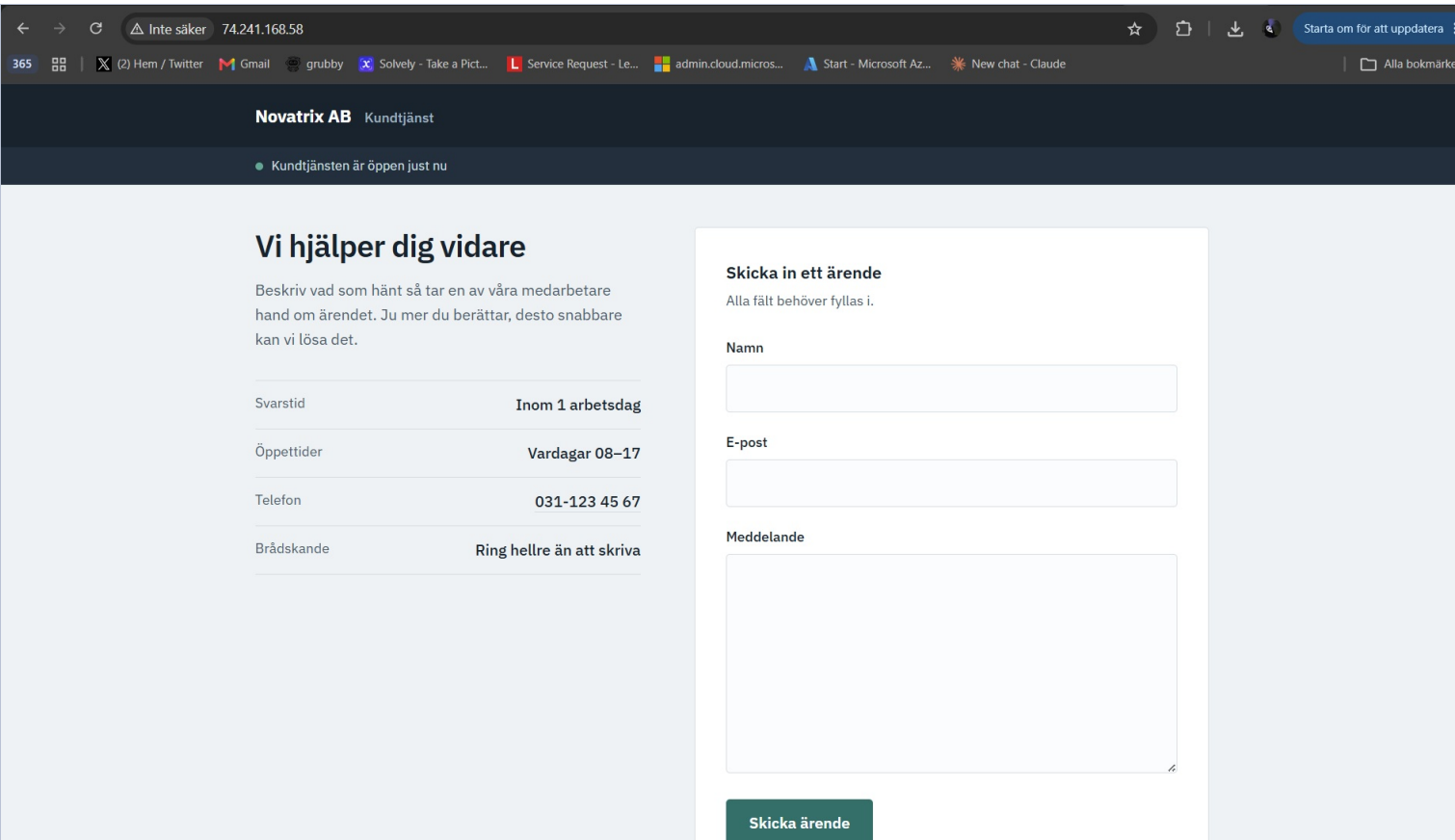
Skärmbild 07. Utdata från ufw status verbose på servern.

Raden `Default: deny (incoming), allow (outgoing)` är kärnan. Servern nekar allt inkommande som standard, och bara port 22 och 80 är uttryckligen öppnade. Även om en NSG-regel skulle råka bli för bred stoppar det här lagret trafiken.

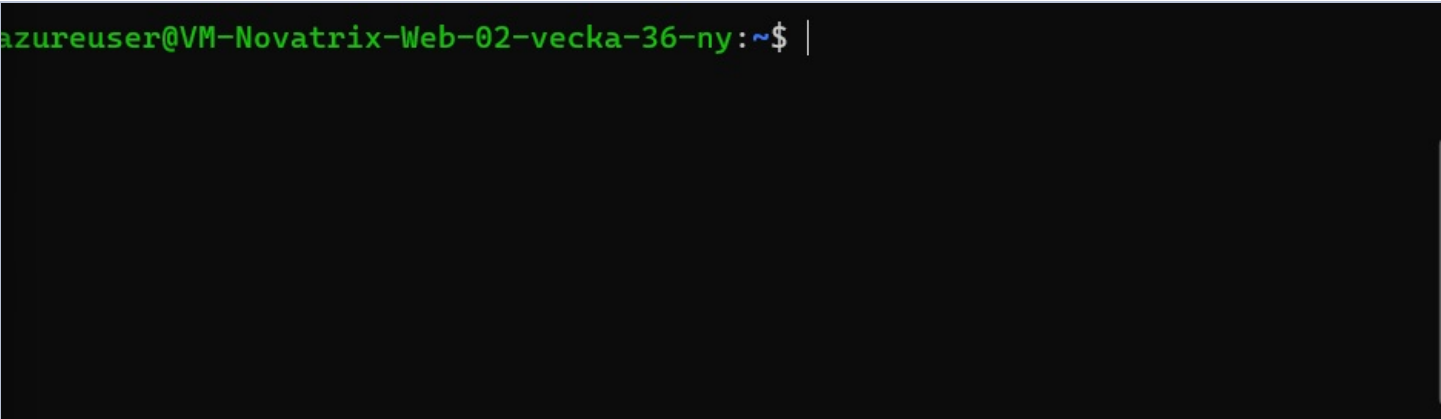
8 Att jag testade att det funkar

Att visa att något fungerar är enkelt. Det som bevisar att skyddet sitter är att visa var trafiken **stoppas**.

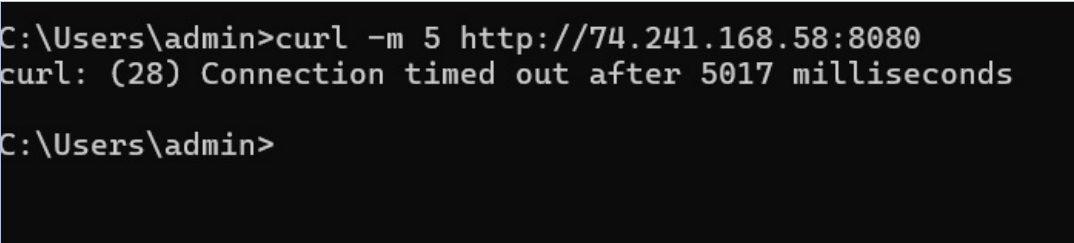
Test	Förväntat	Resultat	Bevis
Öppna sidan i webbläsaren	Ska funka	Sidan laddades	Skärmbild 08
SSH från min dator	Ska funka	Jag kom in	Skärmbild 09
Ansluta till port 8080	Ska nekas	Timeout, inget svar	Skärmbild 10
Port 80 från internet, testat i Azure	Tillåten	Allow-HTTP	Skärmbild 11
Port 22 från annan IP, testat i Azure	Nekad	DenyAllInBound	Skärmbild 12



Skärmbild 08. Kundtjänstsidan svarar på 74.241.168.58.



Skärmbild 09. Inloggad på servern via SSH.



Skärmbild 10. curl mot port 8080 får inget svar och tar slut på tid.

Port 8080 är aldrig öppnad i någon regel. Anslutningen får inget svar alls och tar slut på tid efter fem sekunder. Att det blir tyst snarare än ett avvisande är typiskt för en brandvägg som släpper paketen utan att svara.

Verifiering med Azures eget verktyg

De två sista testen gjorde jag med **Verifiera IP-flöde** i Network Watcher. Det är starkare bevis än att bara visa att sidan laddar, eftersom Azure själv svarar på om trafiken hade släppts igenom, och talar om vilken regel som avgjorde det.

Network Watcher | Verifiera IP-flöde

Microsoft

Sök

Översikt

Kom igång

Övervakning

Diagnostiska verktyg för nätverk

Verifiera IP-flöde

NSG-diagnostik

Nästa hopp

Gällande säkerhetsregler

VPN-felsökning

Paketinspelning

Felsökning av anslutning

Mått

Loggar

Lokal IP-adress * ⓘ

Lokal port * ⓘ

Fjärr-IP-adress * ⓘ

Fjärrport * ⓘ

Kontrollera IP-flödet

Inkommande

Utgående

10.20.1.4

80

8.8.8.8

12345

Resultat

✓ Åtkomst beviljad

Säkerhetsregel	Nätverkssäkerhetsgrupp
Allow-HTTP	nsg-public

Skärmbild 11. IP-flödesverifiering för port 80 ger Åtkomst beviljad.

Azure svarar **Åtkomst beviljad** och pekar ut regeln `Allow-HTTP` i `nsg-public`.

Network Watcher | Verifiera IP-flöde

Microsoft

Översikt

Kom igång

> Övervakning

▼ Diagnostiska verktyg för nätverk

Verifiera IP-flöde

NSG-diagnostik

Nästa hopp

Gällande säkerhetsregler

VPN-felsökning

Paketinspelning

Felsökning av anslutning

> Mått

> Loggar

Lokal IP-adress * ⓘ

Lokal port * ⓘ

Fjärr-IP-adress * ⓘ

Fjärrport * ⓘ

☒ Inkommande☐ Utgående

10.20.1.4

22

8.8.8.8

12345

Kontrollera IP-flödet

Resultat

⊗ Åtkomst nekad

Säkerhetsregel

DenyAllInBound

 Ge feedback

Lägg till eller ta bort favoriter genom att trycka på

Skärmbild 12. IP-flödesverifiering för port 22 ger Åtkomst nekad.

Här är svaret **Åtkomst nekad**, och regeln som stoppade trafiken heter **DenyAllInBound**. Det är värt att förstå varför det inte blev **Allow-SSH-Admin** som svarade: testet gjordes från **8.8.8.8**, som inte är min adress. Regel 120 matchade därför inte, och trafiken föll vidare ner genom regellistan tills Azure's inbyggda sistaregel fångade den.

Det är precis det beteendet jag ville bevisa. Port 22 är öppen för mig och stängd för alla andra, och det är regellistans ordning som avgör det.

Gällande regler på servern

nsg-public

Ingående regler

Namn	↑↓	Prioritet	↑↓	Källa	Källportar
Allow-HTTP		100		0.0.0.0/0,::/0	0-65535
Allow-HTTPS		110		0.0.0.0/0,::/0	0-65535
Allow-SSH-Admin		120		31.208.29.95/32	0-65535
AllowVnetInBound		65000		Virtuellt nätverk	0-65535
AllowAzureLoadBalancerInBound		65001		Azure-lastbalanserare	0-65535
DenyAllInBound		65500		0.0.0.0/0,::/0	0-65535

Utgående regler

Namn	↑↓	Prioritet	↑↓	Källa	Källportar
AllowVnetOutBound		65000		Virtuellt nätverk	0-65535
AllowInternetOutBound		65001		0.0.0.0/0,::/0	0-65535
DenyAllOutBound		65500		0.0.0.0/0,::/0	0-65535

Skärmbild 13. Samtliga säkerhetsregler som gäller för nätverkskortet.

Här syns skillnaden i källkolumnen tydligt. `Allow-HTTP` och `Allow-HTTPS` har `0.0.0.0/0`, alltså hela internet — vem som helst får nå formuläret. `Allow-SSH-Admin` har en enda adress. Det är least privilege i praktiken.

Två av standardreglerna är värda att nämna. `DenyAllInBound` på 65500 är den som stänger allt jag inte öppnat, och därför behövde jag ingen egen blockeringsregel. `AllowVnetInBound` på 65000 släpper igenom trafik inom det virtuella nätverket, och det är den som kommer göra att webbservern når lagringen i v37.

9 Vad jag lärde mig

Att en brandväggsregel inte gör någon nytta förrän den kopplas till ett subnät.

Jag skapade NSG:erna först och kopplade dem i ett eget steg, och innan kopplingen fanns var reglerna bara en lista utan verkan.

Att en virtuell maskin inte går att flytta mellan nätverk. Min gamla server låg i nätverket Azure skapade automatiskt i v34, och eftersom nätverkskortet är låst till sitt nätverk fick jag bygga en ny server i det nya subnätet. Det var därför jag byggde nätverket först och servern sist.

Att en nekad anslutning kan stoppas av en annan regel än man tror. Att `DenyAllInBound` fångade SSH-testet istället för min egen regel gjorde att jag förstod hur regellistan faktiskt läses — uppifrån och ner, tills något matchar.

Att RBAC-rollerna från v35 följde med utan att jag rörde dem. Eftersom de ligger på resursgruppen och inte på den enskilda maskinen gäller de den nya servern också. Det var första gången jag såg nyttan av att ha valt rätt nivå.